

Proxy Config Security Review — Status Summary

Revision: 2 **Last modified:** 2026-07-01T13:56:00Z **Status:**
Companion summary of [Status.md](#) (§11.4.56 two-audience).

Page 1 — For the operator / stakeholders (plain language)

We did a careful read-through of the proxy's configuration — both the web proxy (Squid) and the SOCKS5 proxy (Dante) — looking for anything that could **leak information about you or your network**, or that could be **abused if the proxy were ever exposed to the open internet**. Because this is a VPN proxy whose whole job is to hide who and where you are, any such leak matters.

The good news — already solid:

- **Access rules are locked down.** The web proxy only allows secure HTTPS connections on the standard port, denies everything else by default, and keeps its admin interface local-only.
- **No HTTPS "man-in-the-middle" surface.** The proxy passes your encrypted traffic straight through instead of opening it up, so there is nothing there to get wrong.

Being fixed right now (small leaks, no downside to fixing):

- **The proxy was announcing itself.** It added a header revealing its internal name and exact software version to every site you visit — we confirmed this live and are turning it off.
- **Error pages showed the software version** — being suppressed.
- **Your local IP address could be forwarded** on non-encrypted requests. This is the most privacy-sensitive of the four. We are turning it off as a safety measure. (Honest note: we inferred this from the software's default behaviour but could not reproduce it live, so we are fixing it defensively rather than claiming we saw it happen.)

- **The container's internal id could leak** on error pages — being replaced with a neutral name.

Needs your decision (we did NOT change these on our own, because the tight fix could break your connection):

- **DNS could leak** in one operating mode (the web proxy asks a public DNS server directly instead of the private encrypted one). The other mode is already protected. Pointing it at the private resolver is the fix — but only if that resolver is reachable, which is your call.
- **The SOCKS5 proxy would accept anyone** if its port ever escaped the private network, and it could be pointed at internal/cloud-metadata addresses. We applied the safe part of the fix now; locking it down fully needs you to confirm the trusted client range and internal targets so we don't cut off legitimate traffic.

Bottom line: the core access controls are already strong; four minor information leaks are being closed this round with zero connectivity risk; three larger items are flagged for your decision because the safest-possible fix could otherwise break connectivity. One leak was confirmed live; one was fixed defensively and honestly labelled as inferred, not confirmed.

Page 2 — For software engineers

Static config-security review of the proxy data plane (Squid non-intercepting forward proxy + Dante SOCKS5). Findings are FACTs from the review (§11.4.6). Status: **HARDENED / FIXED** (RED→GREEN proven this round) / **TRACKED** (lands this round) / **TRACKED** (operator decision, §11.4.101).

#	Area	Finding / directive	Sev	Status	Evidence
1	Squid ACL chain	deny CONNECT !SSL_ports (443-only) · http_access deny all terminator · manager localhost-only · fail-closed dynamic profile	—	HARDENED	Config (static)
2	Squid TLS	CONNECT pass-through; no https_port/ssl_bump — no intercept surface by design	—	HARDENED (N/A)	By-design
3	Squid via	via on → Via: 1.1 proxy-squid (squid/6.13) (hostname + version) → via off	MED	FIXED	CONFIRMED qa-regression headers red_20
4	Squid version str	httpd_suppress_version_string off → version on ERR pages	MED	FIXED	Squid disclosure

#	Area	Finding / directive	Sev	Status	Evidence
		incl. ERR_TUNNEL_DOWN → httpd_suppress_version_string on			
5	Squid forwarded_for	default → X-Forwarded-For: client-LAN-IP on plain HTTP (privacy-defeating) → forwarded_for delete	HIGH	FIXED	INFERRED default reproducible endpoint defensive (§11.4.45)
6	Squid visible_hostname	absent → container-id leak → visible_hostname helix-proxy	LOW	FIXED	Squid fallback
7	Squid dns_nameservers	dns_nameservers 8.8.8.8 bypasses DoT dnsproxy → DNS leak in static mode (dynamic mitigated by never_direct)	MED	TRACKED (operator)	Re-producible loopback risk (§11.4.45)
8	Dante auth/ client	socksmethod none + client pass from:0.0.0.0/0 → open relay if :51080 escapes the bridge	HIGH	TRACKED	Safe terminating client = confirmed sockd
9	Dante egress	socks pass to:0.0.0.0/0, no command: → SSRF to 169.254.169.254/RFC1918 + BIND	HIGH	FIXED	command socks 169.254.169.254 172.16.172.16 — REPRODUCIBLE internal fast, confirmed external PASS security

References: squid-cache.org config docs (via, `httpd_suppress_version_string`, `forwarded_for`, `visible_hostname`, `dns_nameservers`, `never_direct`); Dante `sockd.conf(5)`; OWASP Server-Side Request Forgery (SSRF).

Composes §11.4.45 (integration-status doc), §11.4.56 (two-audience summary), §11.4.6 (no-guessing — CONFIRMED via vs INFERRED X-Forwarded-For distinguished), §11.4.101 (autonomous-decision-over-blocking — connectivity-risky fixes TRACKED for operator), §11.4.5/§11.4.69 (captured evidence for the confirmed leak).